CYBERSECURITY & APPLIED SYSTEMS

Mobile Security: *Attacks, Spyware,* & Defenses

Threat architecture, operating system internals, and organizational controls



Phones are now the most valuable target in your pocket

1 **Digital assets**

Banking, email, MFA codes, photos, location: one device holds it all.

2 **Always connected**

Always on, always connected, rarely patched on time.

3 **Work and personal data**

Work and personal data share the same device.



PART 01

01

Mobile Platform Attack Vectors

Deconstructing the attack surface across hardware, software, transport, and connected services.

PART 01

Platform Architecture

LAYERS

The Four Tiers

The mobile attack surface has four layers

1 **Device layer**

OS kernel, baseband processors, secure enclaves, bootloader integrity, and hardware sensors.

2 **Application layer**

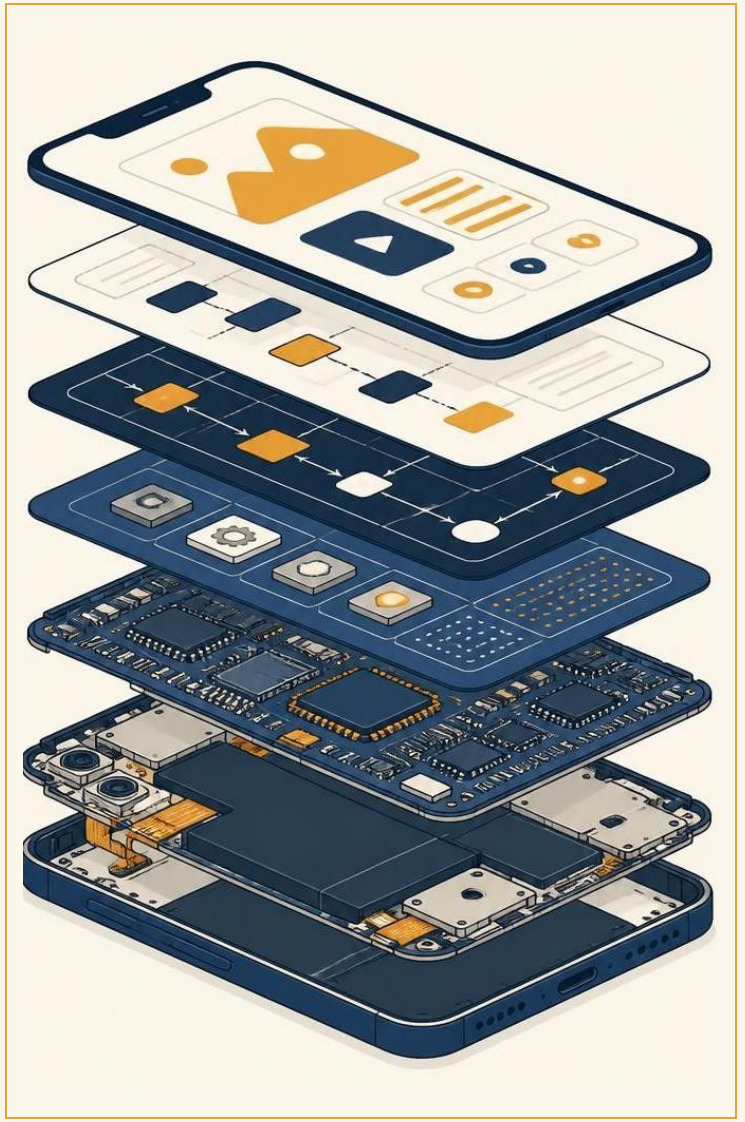
Store packages, sideloaded binaries, IPC channels, webviews, and granted runtime permissions.

3 **Network & radio layer**

Cellular base station handshakes, 802.11 Wi-Fi, Bluetooth stacks, and near-field communications (NFC).

4 **Cloud & backend services**

Mobile API endpoints, cloud backup vaults, push notification conduits, and account sync brokers.



Common attack vectors target people as often as code

Attacks exploit technical vulnerabilities alongside human trust through five primary avenues:

Repackaged Apps

Trojanized APKs or IPAs hosted on third-party repositories mimicking legitimate corporate or banking tools.

Smishing & Phishing

Targeted SMS and instant messaging lure users into entering SSO credentials into deceptive mobile webviews.

Rogue Networks

Hostile access points capturing unpinned TLS traffic and performing active man-in-the-middle packet injection.

Unpatched OS

Known CVEs in WebKit, Chrome, or kernel components left exposed when users postpone manufacturer updates.

Physical Compromise

Lost or stolen devices subjected to brute-force unlock tools, shoulder-surfing, or external debugging extraction.

Defensive takeaway: Technical encryption is useless if an attacker convinces the user to authorize a malicious accessibility service.

OWASP Mobile Top 10 shows where apps fail most

- Improper credential usage and insecure data storage
- Insecure communication and weak authentication
- Insufficient binary protections and supply chain risk
- Use as a checklist when testing any app

PART 02

02

Hacking Android OS

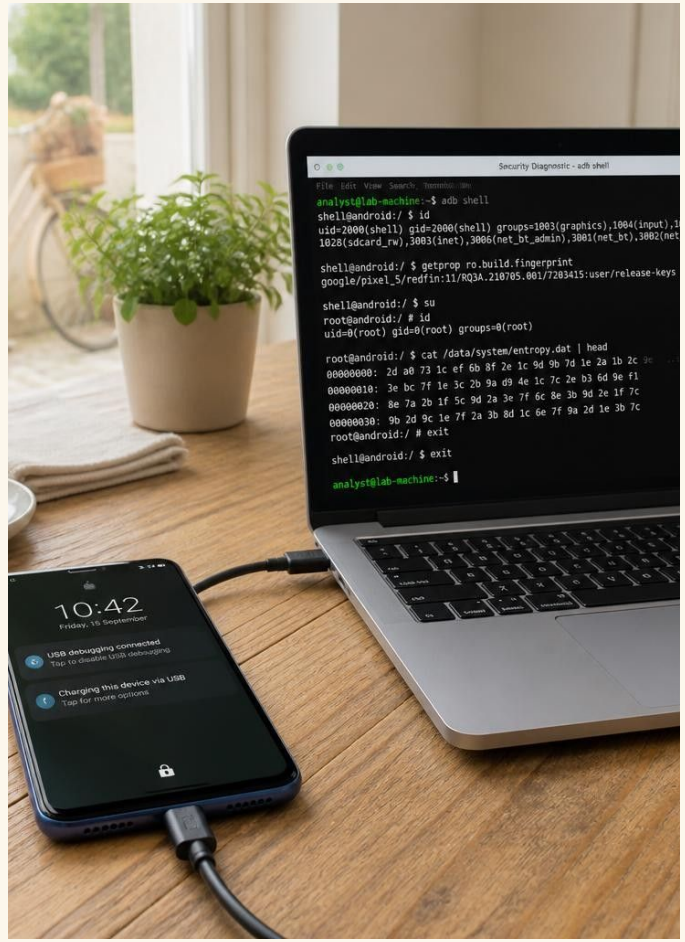
Dissecting Linux-based UID sandboxing, permission hierarchies, overlay mechanics, and ecosystem fragmentation.

Android's security model rests on sandboxing and permissions

1. Linux kernel isolates each app under its own UID
2. Permission model gates sensitive APIs
3. Verified boot and Google Play Protect
4. Fragmented updates widen the exposure window

Android attacks exploit openness and slow patching

- Sideloaded APKs and trojanized apps
- Overlay and accessibility-service abuse
- Rooting that removes sandbox protections
- Exposed components, debuggable apps, ADB left enabled
- Kernel and vendor driver vulnerabilities



PART 03

03

Hacking iOS

Walled-garden controls, mandatory code signing, Secure Enclave processors, and the jailbreak trade-off.

PART 03

iOS Security

LOCKDOWN

iOS locks down the platform through layered controls

1. Mandatory code signing and App Store review
2. App sandbox and Secure Enclave
3. Fast, centralized OS updates
4. Fewer attack paths, but higher value when one is found



Walled Garden

Jailbreaking trades iOS protections for control

- Exploits a kernel or boot-chain flaw to remove restrictions
- Disables code signing and sandbox guarantees
- Opens the door to malware and data theft
- Testers use it deliberately, on lab devices only

PART 04

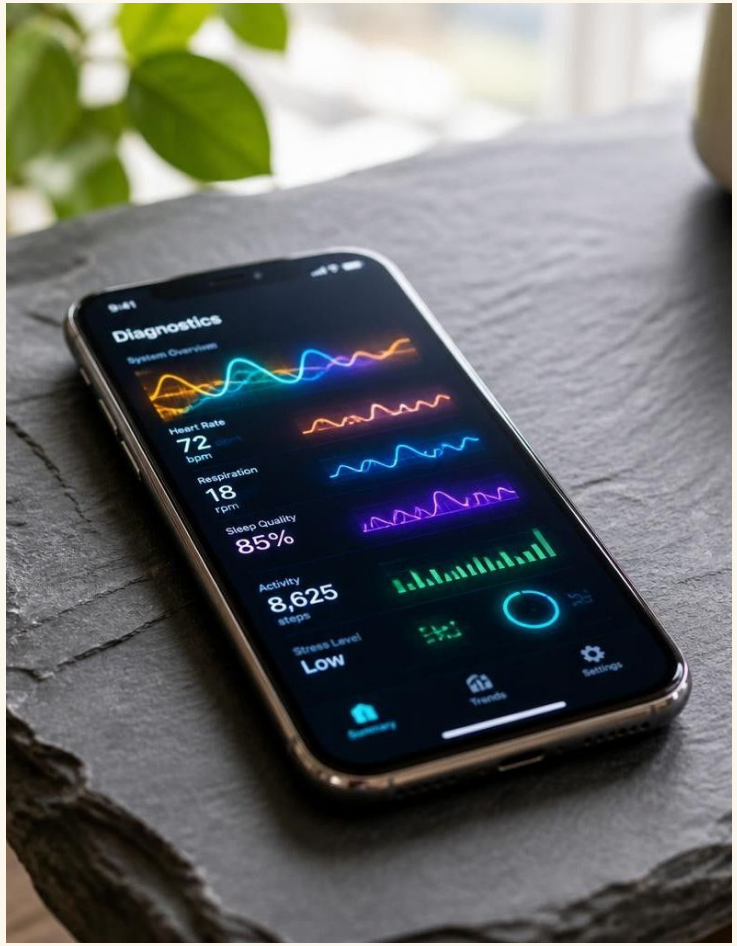
04

Mobile Spyware

From domestic stalkerware to zero-click mercenary surveillance implants deployed by nation-states.

Spyware turns the phone into a surveillance device

- Reads messages, calls, and location
- Activates microphone and camera
- Harvests credentials and app data
- Ranges from stalkerware to state-grade tools



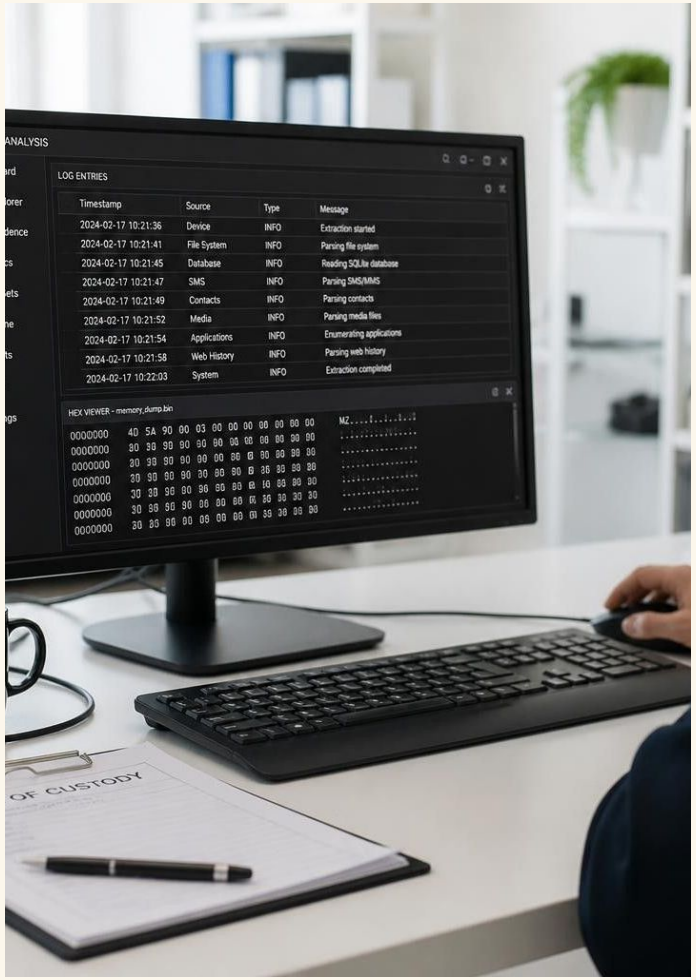
PART 04

Surveillance Tech

PEGASUS

Pegasus showed how zero-click spyware works

1. **Zero-click exploit delivery (FORCEDENTRY):** Sent malformed PDF files disguised as GIF images through iMessage, exploiting an integer overflow in Apple's CoreGraphics image-rendering engine without any user interaction.
2. **Privilege escalation & memory-only residence:** Escaped the iMessage sandbox, compromised the kernel, and operated primarily in volatile memory to evade standard forensic file integrity monitoring.
3. **Forensic discovery with Mobile Verification Toolkit (MVT):** Amnesty International and Citizen Lab identified artifacts in SMS databases, Safari state records, and system shutdown crash logs.



Zero-Click Threat

PART 05

05

Mobile Device Management

Enterprise policy enforcement, hardware enrollment, containerization, and remote cryptographic wiping.

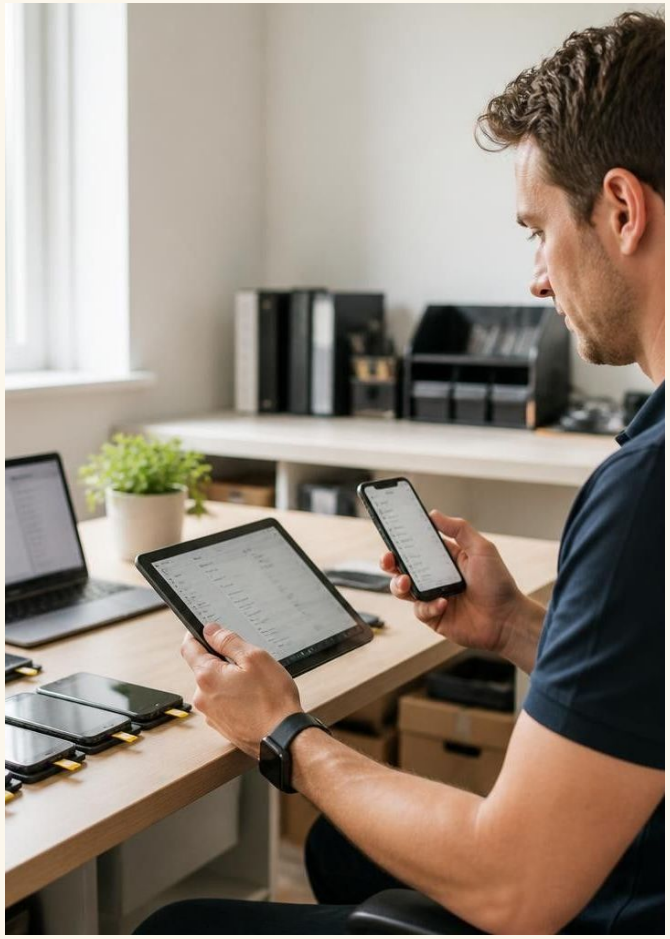
PART 05

Fleet Defense

MDM POWERS

MDM gives organizations control over every enrolled device

- Enroll and configure devices at scale
- Enforce passcodes, encryption, and app allowlists
- Push updates and revoke access
- Remote lock and selective or full wipe



Scale & Control

BYOD and corporate devices need different policies

GOVERNANCE DIMENSION	CORPORATE-OWNED (COPE / COD)	BRING YOUR OWN DEVICE (BYOD)
Device Supervision	Full supervision; enterprise owns the device, hardware, and OS lifecycle.	User-enrolled profile; management limited to a dedicated work sandbox.
Data Containerization	Device-wide encryption, full app control, personal accounts restricted.	Android Work Profile / Apple User Enrollment segregates work files from photos.
Wipe Operations	Full factory reset destroying all partitions upon retirement or loss.	Selective enterprise wipe destroying only corporate tokens and documents.
Access Control	Conditional access requiring hardware compliance before granting VPN access.	MAM (Mobile App Management) container isolation without full device takeover.

Core tenet: On BYOD devices, respect employee personal privacy while strictly isolating enterprise assets in managed containers.

PART 06

06

Mobile Security Guidelines & Tools

Hardening practices, offensive testing frameworks, and incident response runbooks.

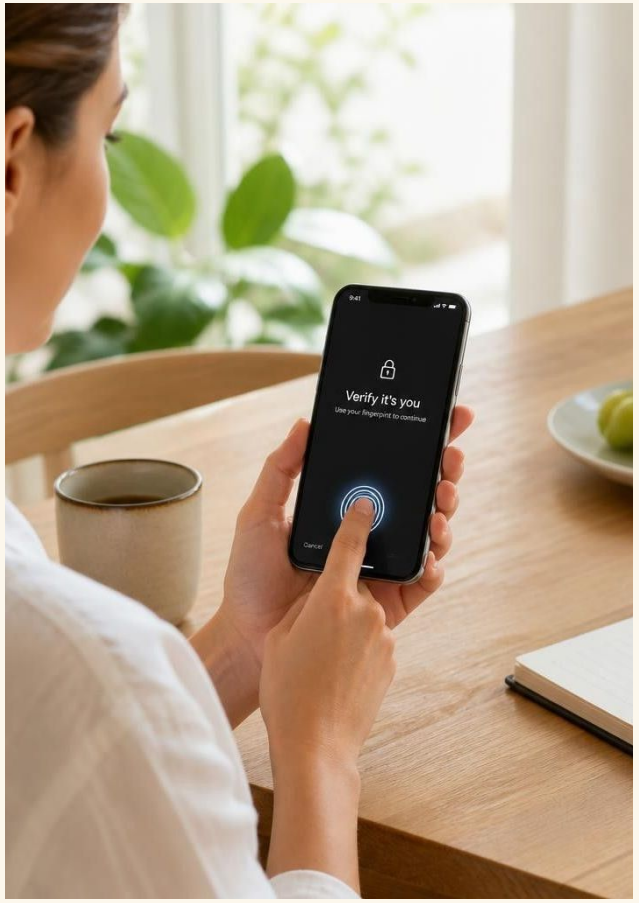
PART 06

Hardening

HYGIENE

Good mobile hygiene blocks most real-world attacks

1. Update the OS and apps promptly
2. Install apps only from official stores
3. Use strong lock screens, biometrics, and MFA
4. Avoid public Wi-Fi or use a VPN
5. Review app permissions and back up encrypted



Testers and defenders rely on a common toolkit

TOOL	USE
MobSF	Static and dynamic app analysis
Frida and Objection	Runtime instrumentation
Drozer	Android attack-surface testing
Burp Suite	Intercept app traffic
MVT	Spyware forensics

PART 06

Incident Response

RUNBOOK

A compromised device needs a fast, structured response

1 2 3 4

1. Isolate

Toggle Airplane Mode, place in a Faraday bag, and remove the physical SIM card immediately.

2. Preserve

Capture volatile memory dumps, system diagnostic sysdiagnose tarballs, and physical disk bitstream images.

3. Revoke

Invalidate all active session refresh tokens, reset SSO credentials, and trigger a remote MDM container wipe.

4. Restore

Re-flash OEM factory firmware, rebuild device configurations from clean source, and update incident logs.

Priority action: Never allow a suspected infected device to reconnect to corporate networks or sync personal cloud backups.

Four-Step Playbook

SUMMARY & REVIEW

Key Takeaways: Know the Attack, Enforce the Defense

THREAT VECTORS

Attackers target apps, wireless networks, and human judgment. Social engineering and smishing routinely bypass technical barriers.

OS PARADIGMS

Android and iOS differ in architectural openness, not inherent risk. Android battles fragmentation; iOS faces concentrated zero-day exploit markets.

MERCENARY SPYWARE

State-grade zero-click spyware circumvents interaction entirely. Defense requires continuous forensic auditing with tools like MVT.

ENTERPRISE FLEET

Strict MDM zero-touch enrollment combined with prompt user hygiene shuts down over 95% of real-world opportunistic mobile intrusion attempts.

Next Session: Mobile Application Reverse Engineering Lab with Frida & MobSF · Thursday, 14:00